

Acme Corp

Network Security Policy

Version 4.0 | Effective: March 1, 2025

Classification: Internal / Confidential

This document is the property of Acme Corp and is intended for internal use only. Unauthorized distribution, reproduction, or disclosure is strictly prohibited. This policy has been approved by the Chief Information Security Officer (CISO) and is effective as of the date indicated above.

1 Purpose and Scope

This policy establishes the requirements for securing Acme Corp network infrastructure, including internal networks, the Cardholder Data Environment (CDE), wireless networks, and external-facing connections. It defines the standards for firewall management, network segmentation, intrusion detection, vulnerability management, and change control procedures for all network components. This policy applies to all network devices, security appliances, and personnel responsible for network operations.

2 Network Security Controls (NSC)

2.1 Firewall Configuration Standards

Configuration standards for all network security control (NSC) rulesets must be defined, documented, and maintained. All firewall rules must be reviewed at least every six months to confirm they are relevant and effective. Firewall ruleset changes must follow the change management process defined in the organizational change control policy. Configuration files for NSCs must be secured from unauthorized access and kept consistent with active network configurations. Default vendor-supplied credentials on all network devices must be changed immediately upon deployment.

2.2 Traffic Control Rules

Inbound traffic to the CDE must be restricted to only traffic that is necessary, and all other traffic must be specifically denied. Outbound traffic from the CDE must also be restricted to only traffic that is necessary for business operations. All allowed services, protocols, and ports must be identified, approved, and have a defined business justification documented. Security features must be defined and implemented for all services, protocols, and ports that are considered insecure to mitigate associated risks.

3 Network Segmentation and CDE Isolation

The Cardholder Data Environment must be isolated from all other networks through proper network segmentation. An accurate network diagram must be maintained that shows all connections between the CDE and other networks, including wireless networks. An accurate data-flow diagram must be maintained that shows all account data flows across systems and networks and must be updated whenever changes occur. DMZ zones must be implemented to limit inbound traffic to only system components that provide authorized publicly accessible services. Private IP addresses must not be disclosed to external entities.

4 Wireless Network Security

NSCs must be installed between all wireless networks and the CDE, regardless of whether the wireless network is part of the CDE. All wireless traffic from wireless networks into the CDE must be denied by default, and only wireless traffic with an authorized business purpose may be allowed. Wireless networks must use WPA3 or WPA2 with AES encryption at minimum. Default wireless encryption keys, passwords, and SNMP community strings must be changed at installation. A wireless intrusion detection system (WIDS) must be deployed to detect and alert on unauthorized wireless access points on a quarterly basis.

5 Vulnerability Management

Internal and external network vulnerability scans must be performed at least quarterly and after any significant infrastructure change. External scans must be performed by a PCI SSC Approved Scanning Vendor (ASV). Penetration testing of the network perimeter and critical systems must be conducted at least annually. High-risk vulnerabilities (CVSS score 7.0 or above) identified during scanning must be remediated within 30 calendar days. Critical vulnerabilities must be patched or mitigated within 72 hours of discovery. All remediation activities must be documented and verified through re-scanning.

6 Network Change Management

All changes to network connections and to configurations of NSCs must be approved and managed in accordance with the organizational change control process. This includes the addition, removal, or modification of any network connection as well as changes that affect how network security controls perform their security function. Change requests must document the business justification, impact analysis, rollback procedures, and security review. Emergency changes must be reviewed and formally approved within 72 hours of implementation. All changes must be tested in a non-production environment before deployment.

7 Network Monitoring and Intrusion Detection

Network-based intrusion detection or prevention systems (IDS/IPS) must be deployed at the perimeter of the CDE and at critical points within the network. All IDS/IPS signatures must be updated within 24 hours of vendor release. Network traffic logs must be captured and retained for a minimum of twelve months, with at least three months immediately available for analysis. Security event monitoring must operate continuously (24/7/365). Automated alerts must be configured for anomalous network activity including unusual traffic patterns, unauthorized connection attempts, and data exfiltration indicators. All critical security alerts must be investigated and documented within four hours of detection.